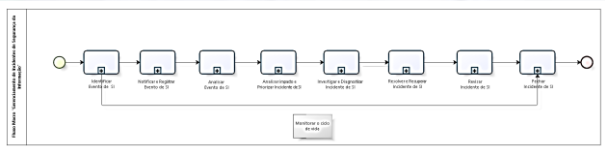
MACRO FLUXO



Atividade	Descrição
Identificar Evento de SI	A identificação de um Evento de Segurança da Informação pode ser realizada por qualquer colaborador da Smiles.
Notificar e Registrar Evento de SI	A notificação e o registro de um Evento de Segurança da Informação pode ser realizada por qualquer colaborador da Smiles. Vale ressaltar: - O nome do colaborador que registrar um Evento de Segurança da Informação, deve ser mantido em sigilo e / ou confidencial pela Gerência de Segurança da Informação; - O colaborador não precisa seguir as regras de hierarquia para abrir um Evento de Segurança da Informação; - Todos os colaboradores devem notificar imediatamente a Gerência de Segurança da Informação sobre possíveis Eventos de Segurança da Informação através ferramenta Jira; - O registro de um Evento de Segurança da Informação deve conter o maior detalhamento possível para análise, diagnóstico e resolução..
Analisar Evento de SI	A Gerência de Segurança da Informação deve analisar todos os Eventos de Segurança da Informação registrados na ferramenta Jira. **Finalizar e informar o colaborador:** Caso o Evento de Segurança da Informação não seja um Incidente de Segurança da Informação, deve finalizar e informar ao colaborador que registrou. **Analisar impacto e Priorizar Incidente de SI:** Caso o Evento de Segurança da Informação seja um Incidente de Segurança da Informação, deve realizar a análise de impacto e priorizar.
Analisar impacto e Priorizar Incidente de SI	A Gerência de Segurança da Informação deve realizar a análise de impacto e priorizar do Incidente de Segurança da Informação.
Investigar e Diagnosticar Incidente de SI	A Gerência de Segurança da Informação deve realizar o diagnóstico inicial e avaliar as evidências em anexo na ferramenta Jira. Vale ressaltar, que deve analisar se haverá necessidade de outras evidências / log´s para realizar o tratamento do Incidente de Segurança da Informação.
Resolver e Recuperar Incidente de SI	A Gerência de Segurança da Informação: - Deve acionar a área de Tecnologia da Informação para solucionar, caso seja técnico através da abertura de um novo incidente de TI na ferramenta Jira. - Deve resolver e recuperar, caso seja administrativo ou não necessite de resolução da área de Tecnologia da Informação.
Revisar Incidente de SI	A Gerência de Segurança da Informação: - Pode solicitar recomendação ou penalização ao Comitê de Segurança da Informação, caso julgue necessário. - Pode solicitar apoio ou comunicação interna / externa de outras áreas da Smiles conforme necessidade.
Fechar Incidente de SI	A Gerência de Segurança da Informação deve finalizar o Incidente de Segurança da Informação na ferramenta Jira. A Gerência de Segurança da Informação deve informar o Infrator da recomendação ou penalização devido ao Incidente de Segurança da Informação cometido. Vale ressaltar, que é opcional a Gerência de Segurança da Informação informar o colaborador da finalização e as ações que foram executadas do Evento de Segurança da Informação registrado.
Monitorar o ciclo de vida	Realizar a monitoração do ciclo de vida de todos os Eventos de Segurança da Informação e Incidentes de Segurança da Informação, caso seja necessário. Vale ressaltar, que a monitoração é efetuada através da ferramenta Jira pela Gerência de Segurança da Informação da Smiles.

Para maiores detalhes, acesse a Política de Segurança da Informação e o link - *https://smiles.atlassian.net/wiki/display/ITSM/ITSM*

Gerenciamento de Incidentes de Segurança da Informação



Gerência de Segurança da Informação

Guia Rápido da Gerenciamento de Incidentes de Segurança da Informação

Versão 01 - 2016

OBJETIVO

- Este processo tem como objetivo identificar, notificar, registar e analisar todos os Eventos de Segurança da Informação.
- E também visa gerenciar de formar eficiente o tratamento dos Incidentes de Segurança da Informação, recomendações ou penalizações e fluxo de comunicação.

ESCOPO

O processo de Gerenciamento de Incidentes de Segurança da Informação tem como escopo:

- Analisar todos os Eventos de Segurança da Informação identificados, notificados e registrados pelos colaboradores;
- Realizar o levantamento de evidências / log´s, investigação, diagnóstico e resolução dos Incidentes de Segurança da Informação com apoio das áreas (Recursos Humanos, Jurídico, Comunicação, Marketing, Tecnologia da Informação, dentre outras);
- Realizar o escalonamento para os Incidentes de Segurança da Informação de alto impacto "Blocker" da Smiles.

Vale ressaltar que o processo de Gerenciamento de Incidentes de Segurança da Informação se relaciona com as normas e diretrizes contidos na Política de Segurança da Informação.

INTERFACES

O Gerenciamento de Incidentes de Segurança da Informação possui interfaces com outros processos, como podem ser vistas nos tópicos abaixo:

Gerenciamento de Mudanças:

- Para resolver uma vulnerabilidade técnica descrita em um Incidente de Segurança da Informação pode ser necessária a abertura de uma *Request for Change* (RFC) que deverá ser aprovada pelo processo de Gerenciamento de Mudanças da Smiles;
- A execução de uma Request for Change (RFC) aprovada pode gerar Eventos de Segurança da Informação durante ou após a sua implantação. É de responsabilidade do processo de Gerenciamento de Mudanças realizar a notificação deste tipo de ocorrência, após a revisão-pós-implantação (RPI);
- É de responsabilidade do Analista de Segurança da Informação participar de todas as reuniões do Comitê Consultivo de Mudanças (CAB) e deliberar pelas *Request for Change* (RFC) avaliando se está aderente as normas e diretrizes de Segurança da Informação.

Gerenciamento de Incidentes de TI:

- Um Incidente de Segurança da Informação pode estar relacionado a um Incidente de TI (mau funcionamento ou comportamento anômalo em um serviço de TI), que possa indicar uma eventual violação e / ou ataque do ambiente. É de responsabilidade do processo de Gerenciamento de Incidentes de TI a notificação deste tipo de ocorrência.

Gerenciamento de Problemas:

- A investigação da causa raiz de um Registro de Problema pode indicar um Evento de Segurança da Informação (vulnerabilidade e / ou ameaças);
- Para resolver um alto índice de Incidentes de Segurança da Informação, pode utilizar as técnicas e / ou procedimentos do processo de Gerenciamento de Problemas.

EVENTO DE SI

São considerados qualquer Evento adverso ou violação desta Política de Segurança da Informação sob suspeita, e relacionado a desvios de confidencialidade, integridade ou disponibilidade das Informações da Smiles. Exemplos de Incidentes de Segurança da Informação incluem, mas não limitam aos mesmos.

- Controle de segurança ineficaz;
- Violação da disponibilidade, confidencialidade e integridade da informação;
- Erros humanos;
- Não conformidade com políticas ou diretrizes;
- Violações de procedimentos de segurança física;
- Mudanças descontroladas de sistemas;
- Mau funcionamento de software ou hardware;
- Violação de acesso.

INCIDENTE DE SI

São considerados qualquer Evento adverso ou violação desta Política de Segurança da Informação confirmado pela Gerência de Segurança da Informação, e relacionado a desvios de confidencialidade, integridade ou disponibilidade das Informações da Smiles. Exemplos de Incidentes de Segurança da Informação incluem, mas não limitam aos mesmos:

- Evasão de informações confidenciais;
- Ataques de engenharia social;
- Uso abusivo ou indevido de redes sociais para difamação, calúnia, ameaças ou fraudes;
- Ausência na utilização de crachá em local visível;
- Não conformidade com políticas ou procedimentos de segurança;
- Comprometimento ou ataques de negação de serviço a sistemas de informação;
- Uso ou acesso não autorizado a sistemas de informação;
- Uso de credenciais de acesso que não sejam de sua propriedade;
- Contaminações por malwares;
- Recebimento de spam através das caixas de e-mail corporativo;
- Cópia ou distribuição não autorizada de material protegido por direitos autorais;
- Utilização de Internet para fazer difamação, calúnia e ameaças;
- Tentativas de ataques a outros computadores;
- Instalação de sistemas não homologados;
- Destruição ou modificações indevidas em informações, sem o conhecimento, instruções ou consentimento prévio do proprietário ou gestor do ativo de informação;
- Alteração do ambiente de produção, sem autorização do processo de Gerenciamento de Mudanças;
- Publicação em ambiente de produção sem aprovação do Comitê Consultivo de Mudanças (CAB) do processo de Gerenciamento de Mudanças;
- Desativação ou remoção de sistemas, como por exemplo, programas antivírus, agente de inventário ou qualquer outro instalado de forma padrão pela área de Tecnologia da Informação, bem como alterar configurações gerenciais das estações de trabalho;
- Quaisquer ações e / ou situações que possam expor a Smiles, parceiros e / ou clientes à perda financeira e de imagem, direta e / ou indiretamente, potenciais e / ou reais, comprometendo seus ativos da Informação;
- Utilizações indevidas de dados corporativos, divulgação não autorizada de informações, segredos comerciais ou outras informações sem a permissão expressa da Gerência de Segurança da Informação e / ou Diretoria de Gestão;
- O uso de dados, informações, equipamentos, software, sistemas, serviços e / ou outros recursos tecnológicos, para propósitos ilícitos, que possam incluir a violação de leis, de regulamentos internos e externos, da ética ou de exigências de órgãos reguladores da área de atuação da Smiles, parceiros e / ou clientes.